Flag 18 of 18: Overwritten PowerShell Build Script

Rogue Synthesis scenario · Cymbal Investments · Google SecOps SIEM

Question

Using the harvested service account to pivot laterally from the developer workstation to a secondary server, what PowerShell script was overwritten by the attacker via PowerShell to establish persistence?

Answer

build_production.ps1

Evidence

- The harvested service account `svc_cicd_deploy` connected from `CYM-DEV-WS-019.cymbal.corp` to `CYM-CI-RUNNER-01.cymbal.corp` using `powershell.exe`. The list view showed 22:50:26, about 21:50:26Z.
- `CYM-CI-RUNNER-01` is the CI/CD build server, the pipeline target named in the scenario briefing.
- A build script that the pipeline runs regularly is a good persistence point: overwriting it makes attacker code run on every production build.
- Evidence status: the answer was accepted in the platform. The overwrite event itself was not pasted in this session, so open it to confirm a write command (such as `Set-Content` or `Out-File`) naming the script, run by `svc_cicd_deploy`.

How it was found

Window: Oct 15 21:50 to Oct 16 00:00 UTC. Searches centered on the service account and the runner host, looking for PowerShell commands that write a `.ps1` file:

```
principal.namespace = "Cymbal"
AND metadata.event_type = "PROCESS_LAUNCH"
AND target.process.command_line = /\.ps1/ nocase
AND target.process.command_line = /Set-Content|Out-File|Add-Content|Copy-
Item|Move-Item/ nocase
```

Lesson

Follow the stolen credential to the next system. In a CI/CD pipeline, scripts the build runs automatically are the places an attacker writes persistence.

Attack chain summary (UTC)

- 20:18 `alex.chen` downloads the lookalike `SyntaxOptimizer-2.1.4.vsix`.
- 20:23 The extension calls the Gemini API.
- 20:25 `gcc.exe` builds `sys_worker.exe`.
- 20:33 `sys_worker.exe` hollows into `svchost.exe` (PID 624).
- 20:46 `credentials.db` is read.
- 20:53 Tokens are sent to `dev-metrics-cdn.com`.
- 21:50 `svc_cicd_deploy` reaches `CYM-CI-RUNNER-01`, and `build_production.ps1` is overwritten.